SOC Interview Questions 3 Rounds

◆ ROUND 1 — Core SOC Fundamentals (40-45 minutes)

Focus: SIEM basics, alert triage, IR fundamentals, networking, log analysis, EDR basics, email security, SOC workflow, KQL basics.

1. SIEM & Log Monitoring

1. What are the main components of a SIEM, and how does it work end-to-end?
2. Difference between *event*, *alert*, *incident*, *offense* in SIEM tools.
3. How do you determine whether an alert is a **true positive** or **false positive**?
4. Walk me through your approach when you receive a *brute-force* alert.
5. What are use cases you worked on in **Azure Sentinel** and **QRadar**?
6. Explain QRadar's **offense rules** and **AQL**.
7. What log sources are most important in a SOC?

2. Incident Response

8. Explain the phases of the **Incident Response Lifecycle**.
9. How do you investigate a **malware alert** from EDR?
10. What indicators tell you that a phishing email is malicious?
11. Steps to investigate **Account Compromise**.
12. What does *Containment* and *Eradication* look like in real cases?

3. EDR & Endpoint Security

13. How does **CrowdStrike Falcon** detect threats?
14. Explain the terms **Process Tree**, **Kill Chain**, **IOC**, **IOA**.
15. What actions can you take from EDR as part of containment?

4. Networking & Security Basics

16. What is the difference between **IDS and IPS**?
17. How do you analyze **firewall logs**?
18. What is the difference between TCP and UDP?
19. Explain DNS monitoring and its importance.

5. Tools & Practical

20. How do you use VirusTotal, AbuseIPDB, URLScan during investigation?
21. Explain Wireshark capture analysis basics.
22. Write a simple KQL query to detect failed logins from a single user.

LOKESH SOC

◆ ROUND 2 — Advanced SOC + Detection Engineering + Threat Analysis (40-45 minutes)

Focus: MITRE ATT&CK, KQL, SIEM tuning, threat hunting, use cases, cloud security, email security, DLP, false-positive reduction.

1. Advanced SIEM & KQL

1. Explain how you tuned Sentinel analytics to reduce false positives by 30%.
2. Write KQL to detect unusual login from a new IP & location.
3. What is the difference between *Scheduled rules*, *NRT rules*, *Fusion rules* in Sentinel?
4. How do you validate the accuracy of a detection rule?
5. Explain **Watchlists** and how you used them.

2. Threat Detection & MITRE ATT&CK

6. Explain the MITRE ATT&CK framework with an example TTP you worked on.
7. How do you map an alert to a specific MITRE technique?
8. Which TTPs are commonly linked to credential abuse?
9. Explain early-stage lateral movement indicators.

3. Threat Hunting

10. Describe a threat hunt you assisted with.
11. What hypotheses do you use for:
    - account compromise
    - privilege escalation
13. How do you classify a threat-hunting finding vs an incident?

4. EDR / Cloud Security

14. What detection gaps exist in CrowdStrike or Defender?
15. Explain how Defender correlates signals across endpoints, email, identity.
16. What is Conditional Access and how do you detect violations?

5. Email Security / DLP

17. How does Proofpoint detect phishing or BEC?
18. What indicators show that an email is part of a credential-harvesting campaign?
19. Explain DLP policy violations and how you triaged them.

6. SOC Process & Reporting

20. What is your incident classification matrix?
21. How do you create an SOP/Runbook — what do you include?
22. What KPIs should be measured for SOC maturity?

LOKESH SOC

◆ ROUND 3 — Scenario-Based + Hands-On Problem Solving (40-45 minutes)

Focus: Real-time incident scenarios, logs, triage decisions, escalation justification, IR deep-dive, vulnerability management, cloud logs, correlation logic, RCA.

1. Scenario-Based Questions

1. You see 50 failed logins followed by a successful login. What do you do?
2. User reports suspicious email with an invoice attachment — walk me through your investigation.
3. You detect a PowerShell script communicating with an unknown IP — next steps?
4. CrowdStrike shows a process spawning cmd.exe → powershell.exe → wget.exe. What does it indicate?
5. Sentinel shows multiple logins from *two countries* within minutes — how do you respond?
6. QRadar offense shows port scanning from an internal machine — actions?

2. Log Analysis

7. Given a firewall log showing multiple outbound 443 connections to rare IPs, what do you check?
8. What indicators differentiate malware vs PUA?
9. In DNS logs, how do you detect DGA domains?

3. Detection Engineering / Use Case Design

10. Build a detection use case for:
    - privilege escalation
    - impossible travel
    - malware execution using LOLBins
11. How do you create correlation rules to detect lateral movement?
12. How do you avoid rule fatigue and alert overload?

4. IR & RCA

13. Provide an RCA structure for a malware infection incident.
14. What artifacts do you collect during IR?
15. How do you decide whether to escalate to L2/L3 or IR team?

5. Cloud & Vulnerability Management

16. How do you investigate suspicious Azure AD sign-ins?
17. Explain how Nessus severity and CVSS scoring impact remediation.
18. How do you prioritize vulnerabilities across 1000 assets?

6. High-Pressure SOC Scenarios

19. What if multiple high-severity alerts come at the same time?

LOKESH SOC

20. How do you handle conflicting data during an investigation?
21. How do you maintain accuracy while working in a fast-paced 24/7 SOC?

LOKESH SOC